Monitorización en Ciberseguridad

Módulo 6: Seguridad en Red II

Máster en Seguridad TIC (XIII edición)

Gonzalo Gómez Gracia
Javier García Aguilar
José Manuel Peña Ramírez
Juan Antonio Robledo Menendez
Raúl Heras Pérez
Raúl Sequera Gómez

3 de abril de 2026

Resumen ejecutivo 3
Línea temporal 3
Impacto real y potencial 4
Impacto real 4
Impacto potencial 4
Mejoras inmediatas 5
ANEXO A. ANÁLISIS L1 6
ANEXO B. THREAT HUNTER - ANÁLISIS SENIOR / BLUE TEAM 7
ANEXO C. GRÁFICAS 8

Resumen ejecutivo

El 21 de marzo de 2026, entre las 06:49 y las 08:12 horas, el servidor de producción srv-prod-01, dedicado al sistema de gestión de recetas, sufrió un ciberataque que resultó en el compromiso total del sistema. Un atacante externo, geolocalizado en Alemania, realizó un ataque automatizado de fuerza bruta contra el servicio SSH, logrando acceder mediante la cuenta del servicio backup_svc, que disponía de privilegios de administrador. Tras el acceso, el atacante creó una cuenta persistente, descargó código malicioso y modificó registros de dispensación de medicamentos correspondientes a 17 pacientes. La alerta inicial fue erróneamente descartada por el analista de nivel 1, lo que retrasó la detección hasta las 08:30. El servidor fue aislado a las 08:32 y el servicio restaurado a las 08:42 mediante un sistema de respaldo. El coste estimado del incidente asciende a 4035€. No se han encontrado evidencias de exfiltración de datos, aunque no puede descartarse hasta que concluya la auditoría externa en curso. La operatividad está actualmente recuperada al 100%.

Línea temporal

Hora	Evento	Sistema afectado
06:49:31	Inicio del ataque de fuerza bruta SSH desde IP 185.220.101.23 (Alemania). 47 intentos en ~90 segundos contra usuarios comunes.	srv-prod-01 (SSH)
06:51:02	Acceso exitoso con la cuenta del servicio **backup_svc**.	srv-prod-01 (SSH)
07:03:14	El atacante ejecuta **sudo adduser admin2**, creación de cuenta persistente con privilegios	srv-prod-01 (SO)
07:03:43	Descarga de **payload.sh** desde IP atacante mediante **wget**. Registro del servidor en sistema C2C.	srv-prod-01 (SO)
07:15:00	Analista L1 silencia la alerta de Wazuh (nivel 10), clasificándola como falso positivo. Sin escalado.	Wazuh SIEM
08:12:05	Acceso remoto con cuenta **admin2** desde segunda IP rusa (195.80.148.133). Modificación de registros de dispensación de recetas.	srv-prod-01 (BD recetas)
08:30:00	El CISO recibe notificación del incidente. Se eleva a nivel crítico y se activa protocolo de respuesta.	-
08:32:00	Aislamiento total del servidor comprometido. Extracción de evidencias con cadena de custodia.	srv-prod-01
08:33:00	Activación del plan de contingencia: servidor paralelo con backup de las 06:00 y rotación de claves.	Servidor de respaldo
08:42:00	Sistema de rescate operativo. Servicio restaurado al	srv-prod-01

Hora	Evento	Sistema afectado
	100%.	(respaldo)
08:50:00	Notificación a INCIBE, REMPe, pacientes afectados. Contratación de auditoría externa. Informe al CEO.	-

Impacto real y potencial

Impacto real

El servidor de producción srv-prod-01 fue comprometido en su totalidad, alcanzando el atacante privilegios de root. Se confirma la modificación de registros de dispensación de medicamentos de 17 pacientes entre las 06:34 y las 08:06. Se creó una cuenta persistente (admin2) y se desplegó un payload que registró el servidor en una infraestructura de mando y control (C2C). La alerta fue silenciada por el analista L1, lo que amplió la ventana de exposición en aproximadamente 75 minutos sin respuesta. El tiempo total de indisponibilidad del servicio de recetas fue de 1 hora y 30 minutos hasta la restauración mediante backup.

Impacto potencial

Aunque no se han encontrado evidencias de exfiltración de datos, el nivel de acceso alcanzado (root) implica que el atacante pudo haber accedido a la totalidad de la base de datos de recetas, incluyendo datos de salud protegidos por el RGPD. La conexión del servidor a un sistema C2C abre la posibilidad de que se hayan ejecutado acciones adicionales no registradas en los logs disponibles. Asimismo, no se puede descartar que la cuenta backup_svc pudiera tener acceso a otros sistemas del entorno.

Concepto	Estimación
Personal médico, enfermería, administrativo y seguridad (1.5h)	225€
Asignación equipos L1 y L2 (1.5h)	84€
Auditoría interna (6h)	900€
Indemnizaciones a pacientes (17 recetas)	1326€
Provisión de fondos adicionales	1500€
Coste total estimado	**4035€**

Mejoras inmediatas

Prioridad	Mejora	Justificación	Responsable	Plazo
Crítica	Deshabilitar autenticación SSH por contraseña e implementar acceso exclusivo mediante claves criptográficas.	Elimina de raíz el vector de ataque utilizado (fuerza bruta). Es la medida con mayor impacto inmediato y menor coste de implementación.	Departamento de IT	24 horas
Alta	Auditoría y restricción de cuentas de servicios: eliminar acceso interactivo SSH de backup_svc, revocar privilegios sudo innecesarios y revisar todas las cuentas de servicio del entorno.	La cuenta comprometida no debería haber tenido acceso interactivo ni privilegios de administración. Corregir esto previene que otras cuentas similares sean explotadas.	Seguridad IAM	48 horas
Alta	Configurar respuesta automática (Active Response) en Wazuh para bloqueo de IPs tras 5 intentos fallidos, y revisar el procedimiento de escalado L1 para que alertas de nivel 10 o superior no puedan ser silenciadas sin validación de un analista senior.	El SIEM detectó el ataque pero no actuó, y el analista L1 descartó la alerta sin escalarla. Esta doble capa (técnica + procedimental) evita que ambos fallos se repitan simultáneamente.	Equipo SOC	1 semana

ANEXO A. ANÁLISIS L1

En Sevilla, a las 08:40:00 horas del día 21 de marzo de 2026.

INCIDENT-0512

Datos clave:

- Servidor comprometido: srv-prod-01
- Servicio principal: sistema de gestión de recetas.
- Dirección IP origen: 185.220.101.23
- Vector ataque: acceso SSH.
- Cuenta comprometida: backup_svc.
- Persistencia: [X] SÍ [ ] NO.
- Lateralidad y/o pivote: no descartados.
- Comandos utilizados: sudo, adduser, wget, psql.

Detalle:

A las 06:49:31 horas se detecta alerta de nivel 10 en SIEM Wazuh por múltiples intentos de conexión SSH desde la dirección IP externa 185.220.101.23 y geolocalizada en Alemania hacia el servidor de producción srv-prod-01, dedicado a la gestión de recetas. El usuario pepe03 de nivel L1 silencia dicha alerta al considerarla un falso positivo.

El análisis de los logs de autenticación evidencia 47 intentos de conexión entre las 06:49:31 y las 06:51:02 horas, con una cadencia constante que confirma la automatización del proceso. A las 06:51:02 se confirma una conexión exitosa con el usuario backup_svc.

De acuerdo a los logs registrados, el primer intento se realiza contra el usuario “admin”, seguido de múltiples intentos contra cuentas habituales (y sus variaciones más habituales) tales como test, root, postgres, user, support, dev, o backup.

A las 07:03:14 se registra el uso del comando adduser con privilegios de superusuario (comando sudo) para añadir un usuario admin2. También se registra la descarga de un fichero llamado payload.sh desde la misma dirección IP con el comando wget a las 07:03:43.

Además, a las 08:12:05 horas se registra un acceso remoto a la nueva cuenta creada admin2 desde la dirección IP 195.80.148.133, también geolocalizada en Alemania. Desde esta cuenta se ha registrado un acceso a la base de datos de recetas dispensadas utilizando la misma cuenta backup_svc entre las 06:34:52 y las 08:06:47 horas.

A las 08:32:09 horas el sistema ha sido totalmente aislado y puesto a disposición de los servicios de auditoría. Todos los datos han sido extraídos y almacenados internamente asegurando la cadena de custodia de acuerdo a los protocolos establecidos.

ANEXO B. THREAT HUNTER - ANÁLISIS SENIOR / BLUE TEAM

En Sevilla, a las 08:47:10 horas del día 21 de marzo de 2026.

TH-0256

Datos clave:

- Informe L1: INCIDENT-0512.
- Nivel de compromiso: crítico.
- Servidor comprometido: srv-prod-01.
- Servicio principal: sistema de gestión de recetas.
- Vectores MITRE ATT&CK: T1110, T1078, T1548, T1136, T1105, T1190.
- Lateralidad y/o pivote: pendientes de investigación.

Detalles:

A las 08:40 horas se recibe informe L1 con identificador INCIDENT-0512 relativo al servidor srv-prod-01 del sistema gestor de recetas. De acuerdo a dicho informe, y tras un análisis a más profundidad de las evidencias custodiadas, se determina que el atacante accedió al sistema debido a una deficiente gestión y configuración de los servicios OpenSSH server y de la cuenta de usuario backup_svc (MITRE ATT&CK: T1110 - Brute Force, T1078 - Valid Accounts).

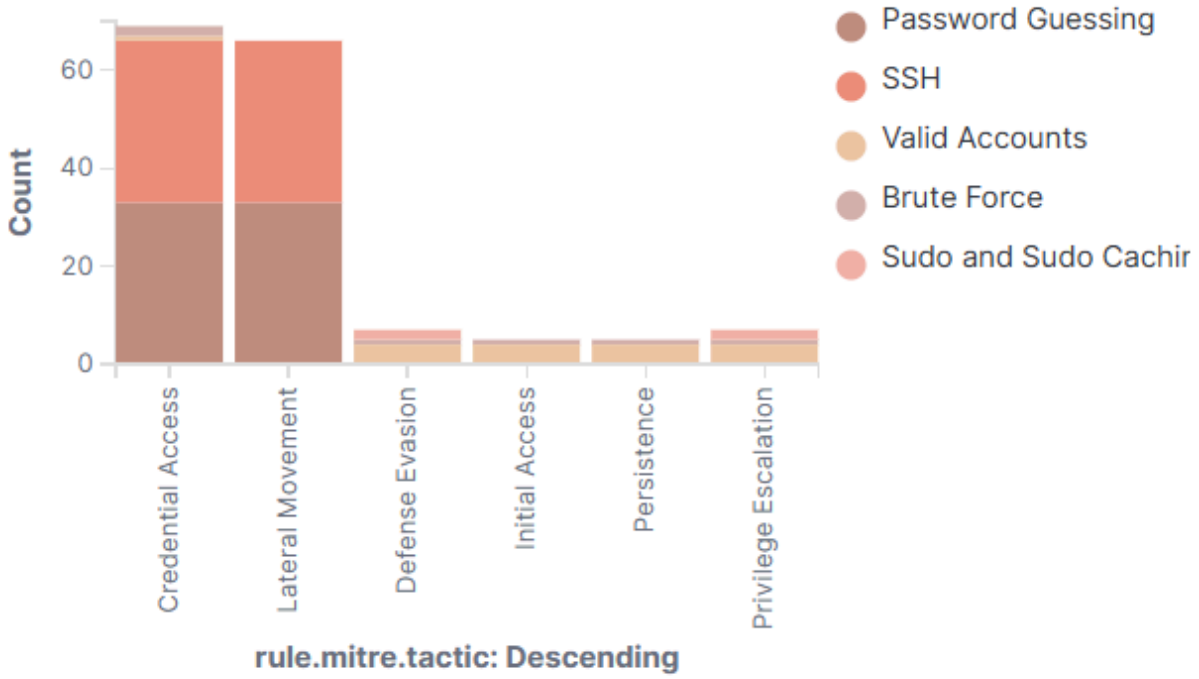
A continuación, el atacante elevó privilegios para crear una cuenta llamada admin2 (MITRE ATT&CK: T1136 - Create Account), y descargó y ejecutó un fichero llamado payload.sh para registrar el dispositivo comprometido en un sistema C2C identificado como BadC2CServer666 (MITRE ATT&CK: T1105 - Ingress Tool Transfer).

Por último, se ha confirmado una conexión desde dicho sistema remoto que ha modificado los registros de dispensación de medicamentos llevados a cabo entre las 06:34:52 y las 08:06:47 horas del día de hoy (MITRE ATT&CK: T1190 - Exploit Public-Facing Application).

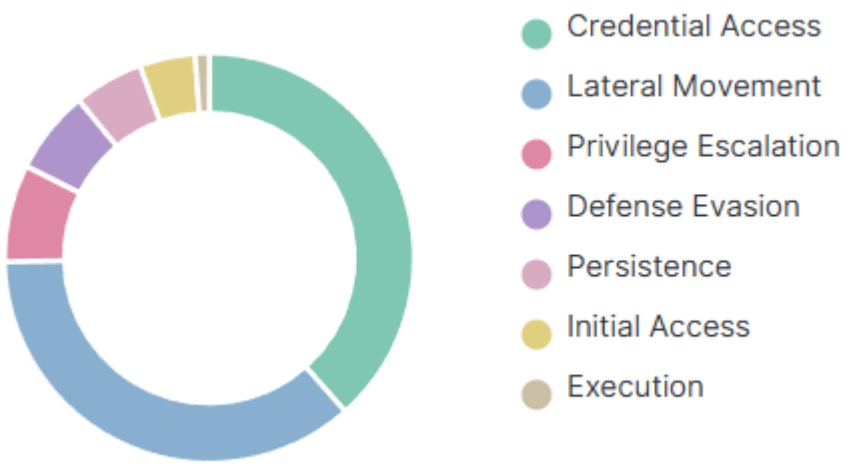
No se ha detectado ninguna acción de extracción de datos de la base de datos, ni ninguna otra anomalía en cuanto a volumen de transferencia de datos en la red interna y/o con salida al exterior que indique que se haya llevado a cabo una exfiltración de datos.

ANEXO C. GRÁFICAS

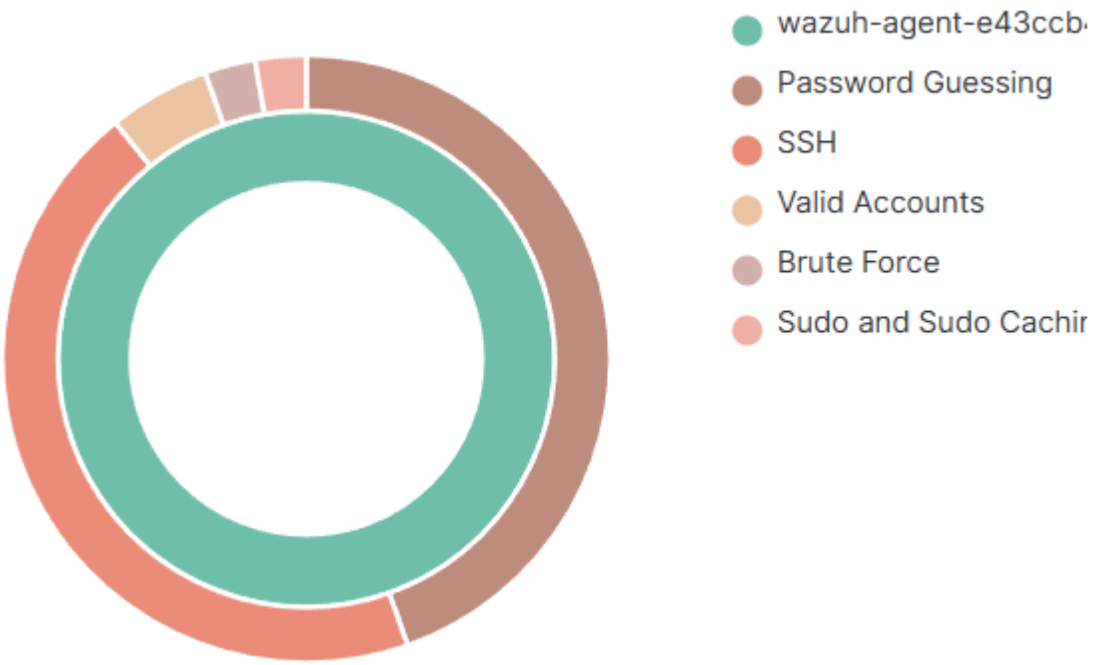
Attacks by technique



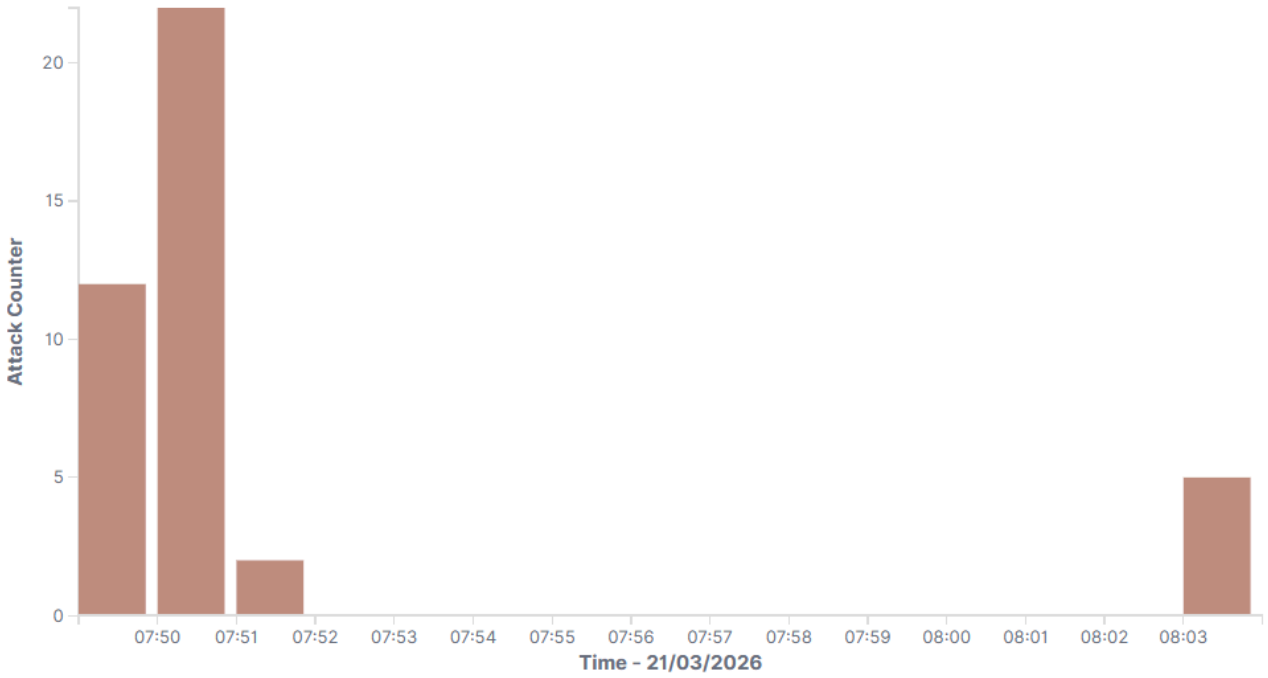
MITRE ATT&CK Tactics



Mitre techniques by agent



Attack Timeline



Level Attacks

282	1	36	90	1
3 - Level Attacks	4 - Level Attacks	5 - Level Attacks	7 - Level Attacks	10 - Level Attacks

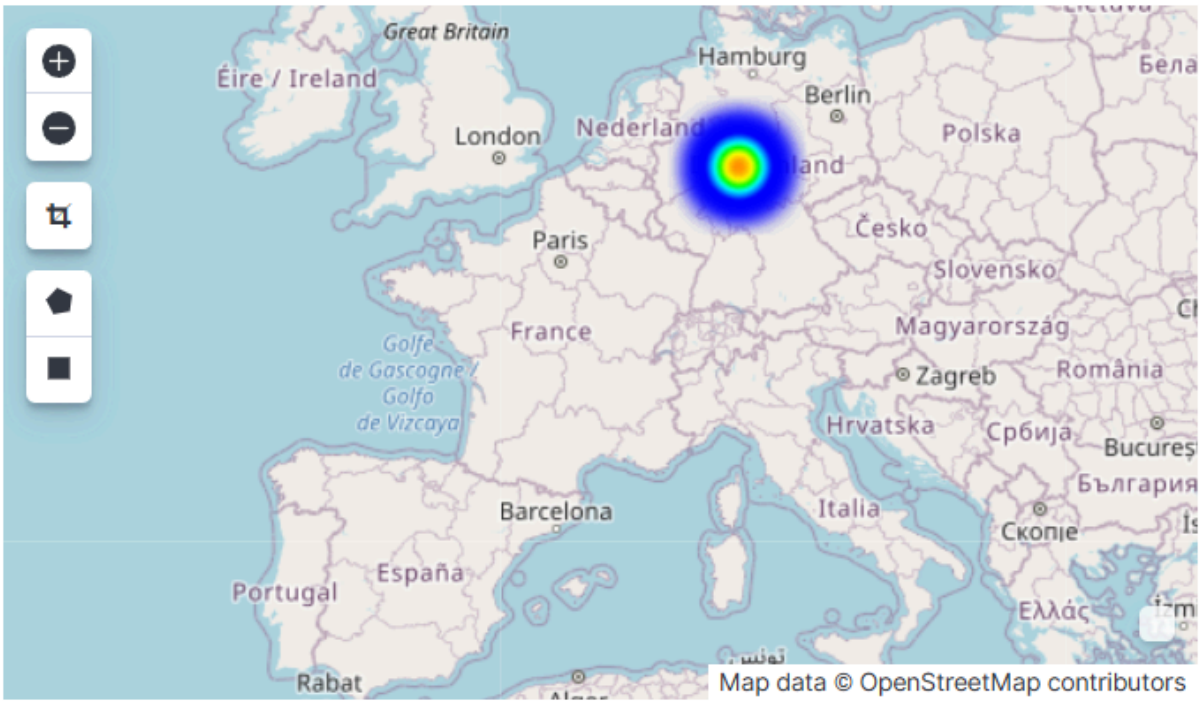
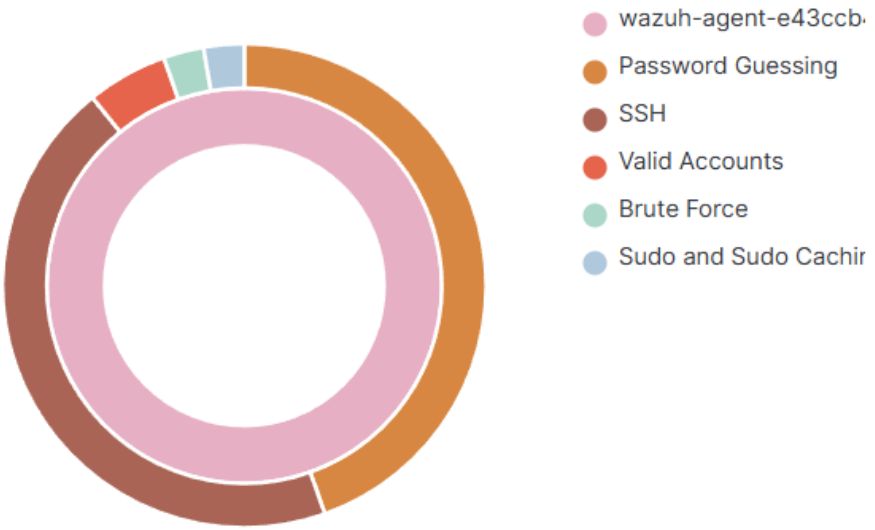
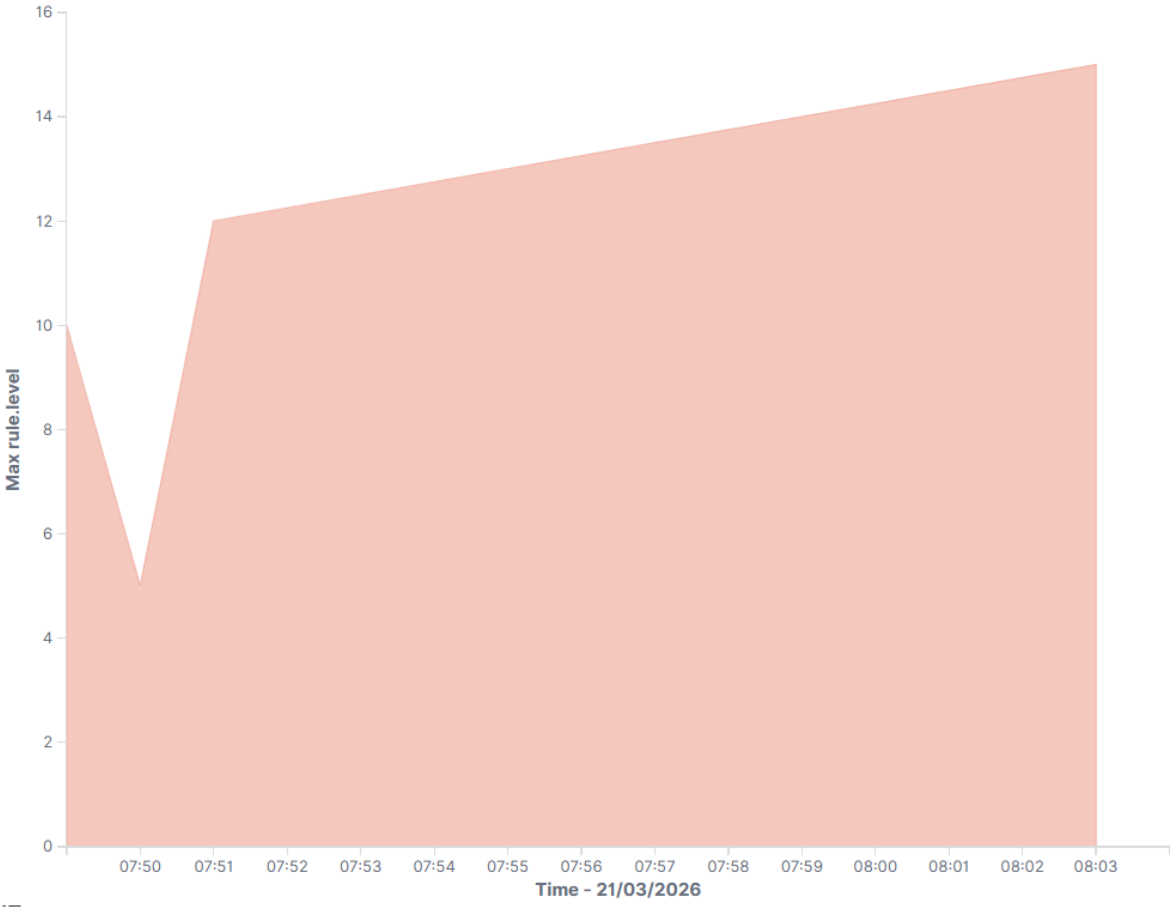
34
- Authentication failure -

3
- Authentication success -

412
- Total -

2
- Level 12 or above alerts -

IP Geolocalization



Mitre techniques by agent